

Understanding and Exploiting JWT ATTACKS

Presented by Vishal Sharma



Quick Overview of Session

- JWT Basics
- Some easy to exploit JWT vulnerabilities.
- JWT Challenge
- Tools to test JWT Related vulnerabilities.
- Some Intermediate Level JWT attacks.
- Q&A

JWT

JWT (JSON Web Token) is a compact, self-contained token format used for **securely transmitting information** between parties as a JSON object. It is commonly used in **authentication and authorization** systems, especially in web applications and APIs.

- It is **divided into three parts**:
1. **Header** – Metadata about the token (algorithm, type).
 2. **Payload** – Contains user data (claims).
 3. **Signature** – Verifies the token's authenticity

JWT STRUCTURE

JSON Web Token Structure

HEADER

Algorithm &
Token type

```
{  
  "alg": "HS256",  
  "typ": "JWT"  
}
```

Base64URL
encode
→

eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXV
CJ9

+

PAYLOAD

Data

```
{  
  "sub": "1234",  
  "name": "RedHunt Labs",  
  "admin": true  
}
```

Base64URL
encode
→

eyJzdWUiOiIxMjM0IiwibmFtZSI6IjI
ZCJ9

+

SIGNATURE

Verification

```
HMACSHA256(  
  base64UrlEncode(header) + "." +  
  base64UrlEncode(payload),  
  secretkey  
)
```

Base64URL
encode
→

zTT7szizs4Gk7xod9psDKhDxt8aX6f0
ECFvIST0qmEA

Easy to Exploit JWT Attacks.

1. JWT contains sensitive information.
2. Resource server does not correctly validate JWT.
3. Expired or Revoked Token is not Rejected.
4. Resource server Accepts the None Algorithm for JWT

4

```
{
  "user": {
    "permissions": [],
    "changeInitialPassword": false,
    "id": "64875c587e491b1226a199f0",
    "firstName": "client",
    "lastName": "client",
    "email": "cli@redacted.com",
    "username": "client",
    "password": null,
    "passwordHistory": [
      "FgQDszcyk0IA3n9rTspCRLwB/Q/TCdJwGIpnf0Q0zy1mIHrhHduC  
R1Jy3pSeVWqjKJdnWU3TlWuyw247jg==",
      "g4tzn8Rw8Y1BRH1sT6SuuvZAX5T22SRfWym1anzoxuB@Yo8KgQSL  
vhmqW15tVjkYx837M/pBe1p2tLCqQ==",
      ""
    ],
    "profileImageUrl":
      "modules/core/users/client/img/profile/default.png",
    "roles": [
      "user"
    ],
    "active": true,
    "azureAD": "",
    "loginAttempts": 0,
    "metadata": {
      "typeOfUser": "CLIENT"
    },
    "created": "2023-03-07T15:46:32.203Z",
    "lastLogout": "2023-04-08T21:12:14.538Z",
    "provider": "local",
    "displayName": "client client",
    "lastPasswordChanged": "2023-03-09T15:42:58.755Z",
    "password": "1",
    "lastLogin": "2023-04-08T21:10:54.633Z",
    "updated": "2023-04-03T08:27:59.971Z",
    "loginToken": null,
    "providerData": null,
    "additionalProvidersData": null,
    "resetPasswordToken": null,
    "resetPasswordExpires": null
  },
  "iat": 16809898346,
  "exp": 1680991946
}
```

Figure 52: In the provided screenshot sensitive information like password history is reflected.

Challenge Time



Some Advance JWT Attacks.

1. Weak JWT Signing Key
2. Key confusion attack.

Weak JWT Signing Key – Testing

How TO Test?

1. Capture the JWT generated by the application
2. Save the following common jwt passwords files in local directory
3. git clone <https://github.com/wallarm/jwt-secrets/>
4. Run the below commands:
5. hashcat -m 16500 -a 0 -w 3 <JSON_WEB_TOKEN>
<PATH_TO_JWT.SECRETS.LIST> (for wordlist attack)
6. hashcat -m 16500 -a 3 -w 3 -i --increment-max=6 <JSON_WEB_TOKEN>
?a?a?a?a?a (bruteforce attack)
7. Observe the output on the command .

Alternate: JWT Editor extention

RS256 to HS256 Vulnerability Test

How TO Test?:

1. Export SSL certificate for the website.
2. Use Below command to get public key .
3. `openssl x509 -in exported_cert.pem -pubkey -noout`
4. Modify the header *alg* to *HS256*
5. Sign the token with public key *obtained using below command*.
6. `openssl x509 -in exported_cert.pem -pubkey -noout`
5. Submit altered token to the server.

Send Cancel < >

Target: <https://altgateway.ext.msb.gov/api/v1/roles> HTTP/1

Request

Pretty Raw Hex Cookies JWS JSON Web Token

```
1 POST /altgateway/ext/MSB_User/api/v1/Roles HTTP/1.1
2 Host: altgateway.ext.msb.gov
3 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:109.0) Gecko/20100101 Firefox/119.0
4 Accept: application/json, text/plain, */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Authorization: Bearer eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9.eyJodHRwOi8vc2NoZWlhc3R5bW9yZy93cy8yMDA1LzAlL2lkZW50aXR5L2NsYWltcy9y9yZWl1IjoideDE4MDAxbiIsImp0aSI6IjUwNzI4MzY4LTE3MDgtNDg5NS05YTczLTJ1ZDAyYTUwNzI1NiIsIm5iZiI6MTY5ODY0Mzc4NSwiZXhwIjoxNjk4NjQ0Njg1LCJpc3MiOiJ0JTVFJTlQxIiwiaXVkiOiJ0VEFFTVNCUCJ9.6mUcMyed1x8ewU3EhaQoffD-dhb2GrsNm94MVJ-TGYiWvBjLITnU5QiiSdghpqSQ5VyEUccHHlbyckZnUhb95jt4GFqaa7RsnXKT6Q0uAYr09JGGQ6F1t-JRrqlRzB9ONBgtOPQGb9BZNPfMy9evvThbilvJj97BVLjopeEj2Pjx6MyH_AG-am13ELnSSNxvi4UdtREkLxJj_MILY2MSuAUyyLneEyFeoU2uwycCJ63FH_mn-XDeTutSUBJVsV2lm3INKu-SHIMbSfK_vnXtmekUuI6C6NP0NJ_68CLF7zyTxiX5mlK4Pkg5VAF1lCpw2vRWSS24oHQ4oLHR20pteA
8 Msbbearer: eyJhbGciOiJSUzI1NiIsInR5cCI6IkpXVCJ9.eyJodHRwOi8vd3d3LnczLm9yZy93cy8yMDA1LzAlL2lkZW50aXR5L2NsYWltcy9y9yZWl1IjoideDE4MDAxbiIsImp0aSI6IjUwNzI4MzY4LTE3MDgtNDg5NS05YTczLTJ1ZDAyYTUwNzI1NiIsIm5iZiI6MTY5ODY0Mzc4NSwiZXhwIjoxNjk4NjQ0Njg1LCJpc3MiOiJ0JTVFJTlQxIiwiaXVkiOiJ0VEFFTVNCUCJ9.6mUcMyed1x8ewU3EhaQoffD-dhb2GrsNm94MVJ-TGYiWvBjLITnU5QiiSdghpqSQ5VyEUccHHlbyckZnUhb95jt4GFqaa7RsnXKT6Q0uAYr09JGGQ6F1t-JRrqlRzB9ONBgtOPQGb9BZNPfMy9evvThbilvJj97BVLjopeEj2Pjx6MyH_AG-am13ELnSSNxvi4UdtREkLxJj_MILY2MSuAUyyLneEyFeoU2uwycCJ63FH_mn-XDeTutSUBJVsV2lm3INKu-SHIMbSfK_vnXtmekUuI6C6NP0NJ_68CLF7zyTxiX5mlK4Pkg5VAF1lCpw2vRWSS24oHQ4oLHR20pteA
9 Content-Type: application/json; charset=utf-8
```

Response

Pretty Raw Hex Render Headers

```
1 HTTP/1.1 401 Unauthorized
2 Cache-Control: no-cache
3 Pragma: no-cache
4 Content-Length: 121
5 Content-Type: application/json
6 Expires: -1
7 GWRqEndTime: 2023-11-07 19:54:55.062710
8 GWRespStartTime: 2023-11-07 19:54:55.062710
9 FailReason: SECUTKN10 :Token expired
10 NavientCorrelationId: 4459aala-5d0a-4
11 Strict-Transport-Security: max-age=86400; includeSubDomains
12 Date: Wed, 08 Nov 2023 00:54:55 GMT
13 Connection: close
14 Strict-Transport-Security: max-age=31536000; includeSubDomains; preload
15
16 {
  "JwtToken": null,
  "RefreshToken": null,
  "ExceptionCode": null,
  "ExceptionMessage": "SECUTKN10 :Token expired",
  "StatusCode": 401
}
```

Inspector

Selection 84 (0x54)

Selected text

```
POST /altgateway/ext/MSB_User/api/v1/Roles HTTP/1.1
```

Decoded from: Select

Cancel Apply changes

Request attributes 2

Request query parameters 0

Request cookies 0

Request headers 16

Response headers 13

Figure 1: Burp repeater showing that session expired error when we use the old access token.

Q&A Session



THANK
YOU

Stay Connected 😊

LinkedIn: <https://www.linkedin.com/in/vish-hal/>

Tweeter: https://x.com/vish_hal

Gmail: Vishalsharmagzb1@gmail.com